

XML Processing Modules

Source code: [Lib/xml/](#)

Python's interfaces for processing XML are grouped in the `xml` package.

Note: If you need to parse untrusted or unauthenticated data, see [XML security](#).

It is important to note that modules in the `xml` package require that there be at least one SAX-compliant XML parser available. The Expat parser is included with Python, so the [xml.parsers.expat](#) module will always be available.

The documentation for the [xml.dom](#) and [xml.sax](#) packages are the definition of the Python bindings for the DOM and SAX interfaces.

The XML handling submodules are:

- [xml.etree.ElementTree](#): the ElementTree API, a simple and lightweight XML processor
- [xml.dom](#): the DOM API definition
- [xml.dom.minidom](#): a minimal DOM implementation
- [xml.dom.pulldom](#): support for building partial DOM trees
- [xml.sax](#): SAX2 base classes and convenience functions
- [xml.parsers.expat](#): the Expat parser binding

XML security

An attacker can abuse XML features to carry out denial of service attacks, access local files, generate network connections to other machines, or circumvent firewalls when attacker-controlled XML is being parsed, in Python or elsewhere.

The built-in XML parsers of Python rely on the library [libexpat](#), commonly called Expat, for parsing XML.

By default, Expat itself does not access local files or create network connections.

Expat versions lower than 2.7.2 may be vulnerable to the “billion laughs”, “quadratic blowup” and “large tokens” vulnerabilities, or to disproportional use of dynamic memory. Python bundles a copy of Expat, and whether Python uses the bundled or a system-wide Expat, depends on how the Python interpreter [has been configured](#) in your environment. Python may be vulnerable if it uses such older versions of Expat. Check `pyexpat.EXPAT_VERSION`.

[xmlrpc](#) is **vulnerable** to the “decompression bomb” attack.

billion laughs / exponential entity expansion

The [Billion Laughs](#) attack – also known as exponential entity expansion – uses multiple levels of nested entities. Each entity refers to another entity several times, and the final entity definition contains a small

string. The exponential expansion results in several gigabytes of text and consumes lots of memory and CPU time.

quadratic blowup entity expansion

A quadratic blowup attack is similar to a [Billion Laughs](#) attack; it abuses entity expansion, too. Instead of nested entities it repeats one large entity with a couple of thousand chars over and over again. The attack isn't as efficient as the exponential case but it avoids triggering parser countermeasures that forbid deeply nested entities.

decompression bomb

Decompression bombs (aka [ZIP bomb](#)) apply to all XML libraries that can parse compressed XML streams such as gzipped HTTP streams or LZMA-compressed files. For an attacker it can reduce the amount of transmitted data by three magnitudes or more.

large tokens

Expat needs to re-parse unfinished tokens; without the protection introduced in Expat 2.6.0, this can lead to quadratic runtime that can be used to cause denial of service in the application parsing XML. The issue is known as [CVE 2023-52425](#).